Module 1: Introduction to SOC

1. SOC Overview

A Security Operations Center (SOC) is a centralized team or function responsible for continuously monitoring an organization's systems, networks, applications, and security events to identify, investigate, and respond to cyber threats.

Main objectives of a SOC:

- Detect suspicious activities and security threats.
- Investigate security alerts.
- Prevent or minimize damage from cyberattacks.
- Respond to security incidents.
- Monitor security controls and maintain visibility.
- Support compliance and security reporting.

Example: If an employee's account suddenly logs in from an unusual location and downloads large amounts of confidential data, the SOC investigates the activity and determines whether it is legitimate or malicious.

2. What Is a SOC?

A SOC combines people, processes, and technology to protect an organization's digital assets.

Component	Description	Example
People	Security professionals	SOC analysts, incident responders
Processes	Defined security procedures	Alert triage, incident response
Technology	Security monitoring tools	SIEM, EDR, firewalls
Data	Information used for investigation	Logs, alerts, network traffic

Types of SOCs: In-house SOC, outsourced SOC, managed SOC, hybrid SOC, and virtual SOC.

Key terms: Security monitoring, threat detection, incident investigation, continuous improvement.

3. SOC Roles and Responsibilities

SOC responsibilities are commonly divided into tiers, although exact job titles and duties vary by organization.

Role	Responsibilities

Tier 1 Analyst	Monitor alerts, validate basic events, perform initial triage, create tickets
Tier 2 Analyst	Investigate complex alerts, correlate logs, determine incident scope
Tier 3 Analyst	Handle advanced threats, threat hunting, malware analysis, detection engineering
Incident Responder	Contain threats, coordinate eradication and recovery
SOC Manager	Manage analysts, processes, metrics, and reporting
Threat Hunter	Proactively search for hidden threats
Detection Engineer	Develop and improve detection rules and analytics

Example: A Tier 1 analyst detects repeated failed logins. A Tier 2 analyst correlates authentication logs and source IP information. If compromise is confirmed, the incident response team coordinates containment.

4. SOC Operations

SOC operations describe the daily activities performed to identify and manage security threats.

Typical workflow:

1. Collect logs and telemetry from endpoints, servers, network devices, and cloud services.
2. Analyze events using SIEM and other security tools.
3. Generate alerts when suspicious patterns are detected.
4. Triage alerts to determine severity and legitimacy.
5. Investigate suspicious activity and gather evidence.
6. Escalate confirmed or complex incidents.
7. Contain threats and support recovery.
8. Document findings and improve detection rules.

Example: A SIEM generates an alert for a suspicious PowerShell command. The analyst reviews the command, endpoint telemetry, user activity, and related events before deciding whether to escalate it.

5. Cybersecurity Foundations

Cybersecurity protects systems, networks, applications, and data against unauthorized access, disruption, modification, and destruction.

Information Security

Information security protects information in any form, including digital files, printed documents, and verbal communications.

The CIA triad is its core model:

- Confidentiality: Only authorized people can access information.
- Integrity: Information remains accurate and unaltered without authorization.
- Availability: Systems and data remain accessible when needed.

Example: Encryption supports confidentiality, file integrity monitoring supports integrity, and redundant servers support availability.

Defense in Depth

Defense in depth uses multiple layers of security so that one failed control does not expose the entire organization.

Examples include firewalls, endpoint protection, MFA, network segmentation, encryption, access controls, backups, and security monitoring.

Example: If a phishing email bypasses the email filter, endpoint protection may block its payload, while SIEM monitoring may detect suspicious activity.

Common Threats and Attacks

Threat or attack	Explanation
Phishing	Deceptive messages designed to steal information or deliver malware
Malware	Malicious software, including ransomware and spyware
Brute force	Repeated attempts to guess credentials
Credential theft	Stealing passwords, tokens, or authentication data
Denial of Service	Making a service unavailable through excessive or malicious traffic
SQL injection	Manipulating database queries through unsafe application inputs
Man-in-the-middle	Intercepting or manipulating communications
Insider threat	Risk caused by malicious or careless insiders
Ransomware	Malware that encrypts data or supports extortion
Privilege escalation	Obtaining permissions beyond those initially granted

Risk Concepts

Risk is commonly evaluated through the likelihood of a threat exploiting a vulnerability and the resulting impact.

- Asset: Something valuable that must be protected.
- Threat: Something capable of causing harm.
- Vulnerability: A weakness that may be exploited.
- Likelihood: The chance that an event will occur.
- Impact: The consequences if it occurs.
- Risk: The potential loss associated with the event.
- Risk treatment: Avoid, mitigate, transfer, or accept risk.

A simplified model is:

$$Risk \approx Likelihood \times Impact$$

This is a conceptual model; organizations may use more detailed scoring methods.

Security Controls

Control type	Purpose	Example
Preventive	Stop an incident before it occurs	MFA, firewall rules
Detective	Identify suspicious activity	SIEM alerts, IDS
Corrective	Restore a secure state	Malware removal, patching
Deterrent	Discourage unwanted behavior	Security warnings
Compensating	Reduce risk when a preferred control is impractical	Additional monitoring
Administrative	Establish rules and responsibilities	Security policies
Technical	Enforce security through technology	Access control, encryption
Physical	Protect physical assets	Locks, access cards

6. Cyber Kill Chain

The Cyber Kill Chain is a model describing stages commonly associated with a cyberattack. It helps analysts understand attacker progression and identify opportunities to disrupt it.

Stage	Description	Possible defensive activity
1. Reconnaissance	Gathering information about a target	External exposure monitoring
2. Weaponization	Preparing a malicious payload	Malware analysis and prevention

3. Delivery	Sending the payload to the target	Email and web filtering
4. Exploitation	Exploiting a vulnerability or weakness	Patching and exploit prevention
5. Installation	Establishing malicious software on a system	EDR detection
6. Command and Control	Communicating with attacker infrastructure	Network monitoring and blocking
7. Actions on Objectives	Achieving goals such as theft or disruption	Data access monitoring and response

SOC application: Analysts use the model to map observed evidence to possible attack stages and identify where controls can interrupt the attack.

7. NIST Cybersecurity Framework

The NIST Cybersecurity Framework (CSF) provides a structured way to manage cybersecurity risks.

The six CSF 2.0 functions are:

Function	Purpose
Govern	Establish strategy, responsibilities, policies, and oversight
Identify	Understand assets, risks, and business context
Protect	Implement safeguards
Detect	Discover possible cybersecurity events
Respond	Manage and contain incidents
Recover	Restore services and improve resilience

Example: An organization identifies critical servers, protects them with access controls, detects suspicious activity through SIEM, responds to incidents, and restores systems using recovery procedures.

8. MITRE ATT&CK

MITRE ATT&CK is a knowledge base of observed adversary tactics and techniques.

- Tactic: Why an attacker performs an action.
- Technique: How the attacker achieves an objective.
- Sub-technique: A more specific method.
- Procedure: A particular implementation observed in an attack.

- Detection: Ways to identify the behavior.

Common tactics include Initial Access, Execution, Persistence, Privilege Escalation, Defense Evasion, Credential Access, Discovery, Lateral Movement, Collection, Command and Control, Exfiltration, and Impact.

Example: If an attacker uses stolen credentials to log in and move between systems, an analyst can map the observed behaviors to relevant ATT&CK tactics and techniques.

Important distinction: The Cyber Kill Chain provides a broad attack progression model; MITRE ATT&CK provides a more detailed catalog of adversary behaviors.

9. SOC Tools and Technology

Tool category	Purpose	Examples
SIEM	Centralize and correlate logs	Splunk, Microsoft Sentinel, Elastic Security
EDR	Monitor and investigate endpoint behavior	Microsoft Defender for Endpoint, CrowdStrike Falcon
NDR / IDS	Detect suspicious network behavior	Suricata, Zeek
SOAR	Automate response workflows	Cortex XSOAR, Splunk SOAR
Threat intelligence	Enrich indicators with threat context	MISP, OpenCTI
Vulnerability management	Identify security weaknesses	Nessus, OpenVAS
Packet analysis	Inspect network traffic	Wireshark
Case management	Track investigations and actions	Jira Service Management, ServiceNow

Tool capabilities vary by edition and configuration. A tool does not replace analyst judgment.

10. Introduction to DFIR

DFIR stands for Digital Forensics and Incident Response.

Digital forensics involves collecting, preserving, examining, and reporting digital evidence. Incident response focuses on managing and recovering from security incidents.

Typical activities include:

- Identifying affected systems.

- Preserving relevant logs and evidence.
- Collecting endpoint, memory, disk, and network artifacts when appropriate.
- Maintaining evidence integrity and chain of custody.
- Investigating the cause and scope of the incident.
- Containing the threat and supporting recovery.
- Documenting findings.

Example: Following a suspected ransomware incident, investigators examine EDR telemetry, Windows event logs, suspicious processes, file changes, and network connections.

11. SOC Maturity Levels

SOC maturity describes how effectively a SOC performs monitoring, detection, investigation, response, and improvement. There is no single universal level system.

A simplified progression is:

Stage	Characteristics
Initial	Reactive, manual processes, limited visibility
Developing	Centralized logging and basic alerting
Defined	Documented procedures, repeatable investigations
Managed	Metrics-driven operations, mature detection and response
Optimized	Continuous improvement, advanced analytics, threat hunting, controlled automation

Assessment criteria: Coverage of critical assets, detection quality, response time, documentation, automation, analyst skills, and improvement processes.

==========

Module 2: Core Skills

This module develops the networking, Windows, Linux, and analytical skills required to investigate security events.

1. Networking Fundamentals I

1.1 OSI Model

The Open Systems Interconnection (OSI) model divides network communication into seven layers.

Layer	Name	Function	Examples
7	Application	Provides network services to applications	HTTP, DNS, SMTP
6	Presentation	Data representation, encoding, encryption	TLS-related data presentation concepts, encoding
5	Session	Establishes and manages communication sessions	Session management
4	Transport	End-to-end transport and port addressing	TCP, UDP
3	Network	Logical addressing and routing	IP, routers
2	Data Link	Local network delivery and MAC addressing	Ethernet, switches
1	Physical	Transmits raw bits over a medium	Cables, radio signals

SOC relevance: Knowing the OSI layers helps identify where suspicious activity occurs. For example, a port scan involves transport-layer information, while unusual IP traffic is examined at the network layer.

1.2 TCP/IP Model

The TCP/IP model describes the protocols used for practical network communication.

Layer	Function	Examples
Application	Application-level network services	HTTP, DNS, SSH
Transport	Communication between processes	TCP, UDP
Internet	Logical addressing and routing	IPv4, IPv6, ICMP
Network Access	Local delivery over the network medium	Ethernet, Wi-Fi

OSI vs. TCP/IP: OSI has seven conceptual layers, while the common TCP/IP model has four. The TCP/IP model reflects how Internet protocols operate in practice.

1.3 Fundamentals of IP Addressing

An IP address identifies a network interface for communication over an IP network.

Important concepts:

- IP address: Logical network address.
- Subnet mask: Identifies the network and host portions of an IPv4 address.

- CIDR prefix: Specifies the number of network bits, such as /24.
- Default gateway: Routes traffic to other networks.
- DNS: Resolves domain names to IP addresses.
- DHCP: Automatically provides network configuration.
- Private IP: Used within private networks.
- Public IP: Routable on the public Internet, subject to network configuration.

1.4 IPv4

IPv4 uses 32-bit addresses, commonly written as four decimal octets.

Example: 192.168.1.10

Each octet ranges from 0 to 255.

Private IPv4 ranges:

Range	CIDR
10.0.0.0–10.255.255.255	10.0.0.0/8
172.16.0.0–172.31.255.255	172.16.0.0/12
192.168.0.0–192.168.255.255	192.168.0.0/16

Example: A computer with 192.168.1.10/24 belongs to the 192.168.1.0/24 subnet. The subnet has 256 total addresses, including network and broadcast addresses in a conventional IPv4 subnet.

Useful commands:

Windows:

ipconfig
ipconfig /all
route print

Linux:

ip addr
ip route

SOC use: Analysts examine IP addresses in firewall logs, authentication events, endpoint telemetry, and network alerts to understand communication patterns.

2. Networking Fundamentals II

2.1 IPv6

IPv6 uses 128-bit addresses and is designed to support a much larger address space than IPv4.

Example:

2001:db8::10

Important IPv6 address types:

- Global unicast: Globally routable address space.
- Link-local: Used on a local link, typically within fe80::/10.
- Unique local: Private-like internal addressing, generally within fc00::/7.
- Multicast: Sends traffic to a group of interfaces.
- Loopback: ::1.

IPv6 supports address abbreviation by omitting leading zeros and compressing consecutive zero groups.

SOC relevance: Analysts must recognize IPv6 traffic, identify unusual connections, and ensure monitoring tools and security policies cover both IPv4 and IPv6.

2.2 Protocols and Ports

A protocol defines rules for communication. Ports help identify services or applications on a host.

Protocol	Common port	Purpose
FTP	21/TCP	File transfer control
SSH	22/TCP	Secure remote administration
Telnet	23/TCP	Unencrypted remote access
SMTP	25/TCP	Email transfer
DNS	53/TCP/UDP	Name resolution
DHCP	67/68 UDP	IPv4 address configuration
HTTP	80/TCP	Web communication
Kerberos	88/TCP/UDP	Authentication
POP3	110/TCP	Email retrieval
IMAP	143/TCP	Email access
SNMP	161/162 UDP	Network management
LDAP	389/TCP/UDP	Directory access

HTTPS	443/TCP	Encrypted web communication
SMB	445/TCP	Windows file sharing
RDP	3389/TCP/UDP	Remote desktop

Ports are conventional defaults; services can be configured to use different ports.

SOC example: Repeated connections to port 3389 from an unfamiliar public IP may indicate exposed remote desktop access or attempted brute-force activity. The analyst must validate the source, destination, authentication logs, and surrounding events.

2.3 Network Devices and Security Roles

Device	Function	SOC relevance
Router	Routes packets between networks	Routing and traffic investigation
Switch	Connects devices within a LAN	Local network visibility
Firewall	Enforces traffic rules	Connection allow/deny logs
IDS	Detects suspicious traffic	Network alerts
IPS	Detects and may block malicious traffic	Prevention events
VPN gateway	Provides encrypted remote connectivity	Remote access investigations
Proxy	Mediates client requests	Web access monitoring
Load balancer	Distributes application traffic	Application traffic analysis
Wireless access point	Connects wireless devices	Wireless access investigations

2.4 Lab: SOC-1 Networking Essentials

Objective: Understand network configuration, connectivity, addressing, and basic troubleshooting.

Tasks:

1. Identify the local IP address, subnet mask, and default gateway.
2. Identify DNS servers and network routes.
3. Test connectivity to an approved lab host.
4. Resolve a domain name using DNS.
5. Inspect active connections.
6. Explain the difference between a listening port and an established connection.

7. Record observations and identify anything unexpected.

Useful commands:

ip addr
ip route
ping <lab-host>
nslookup <lab-domain>
ss -tunap

Use only authorized lab hosts. A failed ping does not necessarily mean a host is offline; firewalls may block ICMP.

3. Windows Fundamentals I

3.1 Windows Architecture

Windows consists of several major components:

- User mode: Runs applications and many operating system services.
- Kernel mode: Provides core operating system functionality.
- Kernel: Handles low-level operations and hardware interactions.
- Windows services: Background processes that provide system functions.
- Registry: Stores system, application, and configuration information.
- File system: Organizes files and directories.
- Security subsystem: Enforces authentication, authorization, and security policies.

SOC relevance: Analysts use process information, services, registry activity, and system logs to investigate suspicious behavior.

3.2 Key System Locations and Files

Location	Purpose
C:\Windows	Core Windows operating system files
C:\Windows\System32	System binaries and libraries
C:\Program Files	Common location for installed applications
C:\ProgramData	Shared application data
%APPDATA%	Current user's roaming application data
%LOCALAPPDATA%	Current user's local application data
C:\Users	User profiles and files

C:\Windows\System32\winevt\Logs	Windows event log files

Important files and components include hosts, services, SAM, and the Windows Registry hives. Access to sensitive files and hives is restricted and should be investigated only with appropriate authorization.

SOC example: An unexpected executable running from a user's temporary directory may deserve investigation, particularly when correlated with suspicious network connections or persistence activity.

3.3 Fundamental Windows Management Tools

Tool	Purpose
Task Manager	View processes and resource usage
Services console	Manage Windows services
Computer Management	Access system administration tools
Device Manager	Inspect hardware and drivers
Registry Editor	Examine registry configuration
Windows Defender Firewall	Review firewall settings
PowerShell	Perform administration and investigation
Command Prompt	Execute Windows command-line utilities
Resource Monitor	Examine processes and resource activity

3.4 Event Viewer and Windows Security Logs

Event Viewer displays events recorded by Windows and applications.

Important log categories:

- Application: Application-generated events.
- System: Operating system and service events.
- Security: Authentication, account, and security audit events.
- Setup: Installation and configuration events.
- Forwarded Events: Events received from other systems.

Useful Windows Security Event IDs include:

Event ID	Meaning
4624	Successful logon
4625	Failed logon

4634	Logoff
4648	Logon using explicit credentials
4672	Special privileges assigned to a new logon
4688	Process creation, when auditing is enabled
4720	User account created
4728	Member added to a security-enabled global group
4740	User account locked out

These events may require the appropriate audit policies and permissions to be enabled. Event IDs must be interpreted with their details and surrounding evidence.

Practical investigation:

1. Open Event Viewer.
2. Navigate to Windows Logs → Security.
3. Filter for event ID 4625.
4. Review account name, source address when available, timestamp, and logon type.
5. Determine whether the failures are isolated or part of a larger pattern.

4. Windows Fundamentals II

4.1 Windows Users and Permissions

Windows accounts represent identities, while permissions control access to resources.

Important concepts:

- Local accounts and domain accounts.
- Standard users and administrators.
- Security groups.
- Access Control Lists (ACLs).
- File and folder permissions.
- User Account Control (UAC).
- Least privilege.

Example: A standard employee account should not have unrestricted administrative access to every endpoint.

Useful commands:

whoami

whoami /groups
net user

PowerShell:

Get-LocalUser
Get-LocalGroup

4.2 Active Directory Basics

Active Directory Domain Services (AD DS) centrally manages identities, computers, groups, and policies in a Windows domain environment.

Component	Description
Domain	Administrative boundary for directory objects
Domain Controller	Server providing directory and authentication services
Organizational Unit	Container used to organize objects and delegate administration
Group Policy	Centralized configuration and policy management
Security Group	Group used to assign access rights
Kerberos	Common domain authentication protocol
LDAP	Protocol used to access directory information
Group Policy Object	Collection of configuration settings applied to users or computers

SOC relevance: Attackers may target privileged accounts, abuse excessive permissions, or attempt lateral movement between domain systems.

Example investigation: An unexpected addition to a privileged security group should be checked against approved change records, the initiating account, event logs, and other administrative activity.

4.3 Windows Command-Line Essentials

Useful commands:

systeminfo
hostname
whoami
ipconfig /all
netstat -ano
tasklist

tasklist /svc
sc query

PowerShell examples:

Get-Process
Get-Service
Get-WinEvent -LogName Security -MaxEvents 20
Get-NetTCPConnection

SOC use: These commands help identify the system, active processes, network connections, services, and recent events. Commands that retrieve sensitive information should be used with appropriate permissions.

4.4 Lab: SOC-1 Windows Essentials

Objective: Investigate basic Windows system and security activity.

Tasks:

1. Identify hostname, operating system, and current user.
2. Inspect local users and groups.
3. Review running processes and services.
4. Inspect network connections.
5. Open Event Viewer.
6. Find successful and failed logon events.
7. Document the timestamp, user, source, event ID, and interpretation of each relevant event.

Deliverable: A short investigation report with observations, supporting evidence, and recommended follow-up.

5. Linux Fundamentals

5.1 Linux Architecture

Linux systems consist of:

- Kernel: Manages memory, processes, devices, and system calls.
- Shell: Provides a command-line interface.
- User space: Runs applications and services.
- File system: Organizes files and directories.
- Init system: Starts and manages services; systemd is common.
- Package manager: Installs and updates software.

5.2 Linux Users, Groups, and Permissions

Linux assigns ownership to users and groups and uses permissions to control access.

Permissions:

- r — read
- w — write
- x — execute

Example:

-rwxr-xr--

The owner has read, write, and execute permissions; the group has read and execute; others have read.

Useful commands:

whoami
id
ls -l
chmod 640 file.txt
chown user:group file.txt

Use sudo only when authorized. Avoid granting unnecessary privileges.

5.3 Linux Command Line

Command	Purpose
pwd	Show current directory
ls -la	List files, including hidden files
cd	Change directory
cat	Display file contents
less	View a file page by page
grep	Search text
find	Search for files
ps	List processes
top	Monitor processes
journalctl	Read systemd journal logs
systemctl	Manage services
ip addr	Show IP configuration
ss -tulpn	Inspect listening sockets

5.4 Linux Processes and Services

A process is a running instance of a program. A service is a background component that provides a function.

Useful commands:

ps aux
top
systemctl --type=service
systemctl status ssh

SOC relevance: Unexpected processes, unfamiliar services, suspicious parent-child process relationships, and unexplained network listeners may indicate compromise.

5.5 Linux Networking

Linux networking involves interfaces, routes, DNS resolution, sockets, and firewall rules.

Useful commands:

ip addr
ip route
ss -tuna
getent hosts example.com

For logs, common locations include /var/log/, the systemd journal, and service-specific logs. Exact locations vary by distribution and configuration.

Common authentication log locations include /var/log/auth.log on many Debian-based systems and /var/log/secure on many RHEL-based systems.

6. Analyst Mindset

6.1 Thinking Like an Analyst

A SOC analyst evaluates evidence instead of immediately assuming that an alert proves an attack.

A useful process is:

1. Define the alert or question.
2. Identify the relevant assets, identities, and time range.
3. Gather supporting evidence.
4. Develop possible explanations.
5. Test those explanations.
6. Assess the likelihood and impact.
7. Document the conclusion and remaining uncertainty.

6.2 Pattern Recognition

Pattern recognition identifies relationships across events.

Examples include repeated failed logins, unusual login times, unexpected privilege changes, suspicious parent-child processes, and outbound connections to unusual destinations.

Example: One failed login may be harmless. Hundreds of failures against multiple accounts from the same source may suggest password spraying or brute-force activity.

6.3 Avoiding Bias

Common analytical biases:

- Confirmation bias: Looking only for evidence that supports an initial belief.
- Availability bias: Overestimating a threat because it was recently encountered.
- Anchoring: Giving too much weight to the first alert or explanation.
- False certainty: Treating incomplete evidence as conclusive.

Analysts should consider alternative explanations, verify assumptions, and distinguish facts from hypotheses.

6.4 Compliance, Privacy, and Data Handling

SOC analysts often handle personal data, business-sensitive records, authentication information, and forensic evidence.

Best practices include data minimization, access control, encryption, approved retention, secure sharing, and proper evidence handling.

Important: Do not copy sensitive logs or personal information into unauthorized tools or public services. Follow organizational policies and applicable legal requirements.

==========

Module 3: SOC Tools and Technology

This module explains how security tools work together to detect, investigate, and respond to threats.

1. SOC Foundations

1.1 Evolution of SOCs

SOC operations have evolved through several stages:

- Traditional monitoring: Manual review of logs and security alerts.

- Centralized logging: Collecting logs from multiple systems into a common platform.
- SIEM-based monitoring: Correlating events and applying detection rules.
- Integrated security operations: Combining SIEM, EDR, threat intelligence, and incident management.
- Modern SOC: Using cloud telemetry, threat hunting, automation, behavioral analytics, and AI-assisted investigation.

The goal is to improve visibility, reduce investigation time, and respond more consistently.

1.2 Modern Threat Landscape

Modern threats target endpoints, identities, cloud infrastructure, applications, networks, and supply chains.

Common trends include:

- Phishing and business email compromise.
- Ransomware and data extortion.
- Stolen credentials and session tokens.
- Cloud misconfigurations and exposed storage.
- Exploitation of vulnerable applications.
- Supply-chain compromise.
- Insider threats.
- Living-off-the-land techniques that misuse legitimate system utilities.

SOC task: Understand the threat, identify observable evidence, determine which assets are affected, and establish the appropriate response.

1.3 Tool Categories

SOC tools are grouped according to their purpose.

Category	Function
SIEM	Log collection, correlation, searching, and alerting
EDR	Endpoint monitoring, investigation, and response
NDR	Network detection and analysis
IDS/IPS	Detecting and, in IPS configurations, blocking suspicious traffic
SOAR	Orchestrating and automating security workflows
Threat intelligence	Providing context about indicators and threats
Vulnerability scanners	Identifying known weaknesses
Forensic tools	Examining digital evidence

Ticketing tools	Tracking investigation and remediation
Cloud security tools	Monitoring cloud identities, configurations, and activity

1.4 Analyst Role and Daily Tool Interactions

Typical daily activities include checking alert queues, reviewing dashboards, investigating authentication events, examining endpoint activity, enriching indicators, creating tickets, escalating incidents, and documenting findings.

Example workflow: A SIEM detects an unusual login. The analyst checks authentication logs, enriches the source IP using approved intelligence sources, checks endpoint telemetry, and documents the outcome in a case management system.

2. Tool Architecture and Core SOC Platforms

2.1 Understanding Tool Integration and Data Flow

Security tools often exchange information through agents, APIs, log forwarders, message queues, and integrations.

A typical architecture is:

- Data Sources
- Endpoints, servers, firewalls, cloud services, applications
- Collection and Normalization
- Agents, APIs, log forwarders, parsers
- SIEM and Analytics
- Search, correlation, rules, alerts
- Investigation and Response
- EDR, threat intelligence, SOAR, ticketing

Important concepts:

- Ingestion: Receiving data.
- Parsing: Extracting fields from raw records.
- Normalization: Representing data consistently.
- Correlation: Connecting related events.
- Enrichment: Adding context such as asset ownership or threat intelligence.
- Alerting: Notifying analysts when detection conditions are met.

Integration problems, missing logs, incorrect timestamps, and parsing errors can affect detection quality.

2.2 Endpoint Detection and Response (EDR)

EDR monitors endpoint activity and helps detect, investigate, and respond to threats.

Typical capabilities include:

- Process and command-line monitoring.
- File and registry activity monitoring.
- Network connection visibility.
- Detection of suspicious behavior.
- Investigation timelines.
- Endpoint isolation and other response actions, where supported.

Example: An EDR detects an office application launching an unusual script interpreter, followed by suspicious network communication. The analyst investigates the process tree, command line, user, and destination.

EDR is not the same as traditional antivirus. EDR typically provides richer behavioral telemetry and investigation capabilities.

2.3 SIEM Overview

A Security Information and Event Management (SIEM) platform collects and analyzes security-related data from multiple sources.

Main functions:

- Centralized log storage and search.
- Event correlation.
- Detection rules and alert generation.
- Dashboards and reporting.
- Investigation support.
- Integration with other security tools.

Examples include Splunk Enterprise Security, Microsoft Sentinel, and Elastic Security.

2.4 SIEM Rules

A SIEM detection rule identifies a pattern or condition that may indicate suspicious activity.

Example rule logic:

```
IF
   failed_login_count >= threshold
   within a defined time window
   for a user or source
THEN
   generate a security alert
```

The threshold must be tuned to the environment.

Rule types include threshold-based rules, correlation rules, sequence-based rules, anomaly-based detections, and scheduled searches.

Good detection rules should have a clear purpose, appropriate data sources, meaningful thresholds, severity, context, and documented investigation steps.

False positive: An alert that indicates malicious activity when the activity is legitimate.

False negative: Malicious activity that the detection fails to identify.

2.5 Security Orchestration, Automation and Response (SOAR)

SOAR connects security tools and automates repeatable parts of an investigation or response.

Examples of tasks that may be automated:

- Enriching an IP address.
- Checking a file hash against approved intelligence sources.
- Opening a case.
- Notifying an analyst.
- Disabling an account after an authorized decision.
- Isolating an endpoint when the relevant conditions and approval requirements are satisfied.

Automation must include appropriate access control, safeguards, error handling, and audit logging.

2.6 SOAR Playbooks

A playbook is a documented sequence of actions for handling a particular type of alert.

Example: Suspicious Login Playbook

1. Receive the suspicious-login alert.
2. Retrieve authentication logs.
3. Check user identity, source IP, location context, and device.
4. Review MFA results and recent account changes.
5. Enrich indicators using approved sources.
6. Determine whether the activity is expected, suspicious, or confirmed malicious.
7. Escalate or initiate approved containment actions.
8. Record evidence, decisions, and the final outcome.

A playbook should specify decision points, responsibilities, approval requirements, failure handling, and closure criteria.

3. Threat Intelligence and Analysis Capabilities

3.1 Threat Intelligence

Threat intelligence is analyzed information about threats that helps an organization make security decisions.

Common categories:

- Strategic intelligence: Business-level risks and trends.
- Operational intelligence: Campaigns, adversary objectives, and attack context.
- Tactical intelligence: Attacker tactics and techniques.
- Technical intelligence: IP addresses, domains, file hashes, and other technical indicators.

Useful sources may include trusted vendor reports, government advisories, ISACs, and approved intelligence platforms.

3.2 Indicators of Compromise (IoCs)

An IoC is an observable artifact that may indicate malicious activity.

IoC	Example
IP address	An IP associated with known malicious infrastructure
Domain	A domain linked to phishing or command and control
File hash	SHA-256 hash associated with a malicious sample
File path	An unexpected executable in a suspicious directory
Email indicator	A known malicious sender or phishing URL
Registry artifact	An unauthorized persistence-related change
Process indicator	A suspicious process command line

Important: An indicator alone does not prove compromise. Indicators may be outdated, shared by legitimate services, or context-dependent.

3.3 Threat Intelligence and IoC Enrichment

Enrichment adds information to an indicator to support investigation.

For an IP address, enrichment may include ownership, ASN, reputation, geolocation estimates, historical observations, and related threat reports.

For a file hash, it may include file type, signature information, detection results, and known relationships.

Analyst process:

1. Extract the indicator.
2. Validate its format.
3. Query authorized intelligence sources.
4. Evaluate the source's reliability and the information's age.
5. Correlate results with internal telemetry.
6. Document confidence and limitations.

Do not treat a reputation score or geolocation result as conclusive evidence.

3.4 Threat Intelligence and IoC Enrichment Demonstration

Example exercise: Investigate a suspicious domain found in a simulated email alert.

1. Extract the domain from the email.
2. Check the organization's internal DNS and proxy logs.
3. Consult an approved domain-reputation source.
4. Review registration and infrastructure context when available.
5. Determine whether users accessed the domain.
6. Identify related endpoint or authentication activity.
7. Record evidence and recommend follow-up.

Use training indicators or authorized test data rather than interacting with unknown malicious infrastructure.

3.5 Advanced Analysis Tools

Tool	Purpose
Wireshark	Packet capture analysis
Zeek	Network metadata and protocol analysis
CyberChef	Data decoding and transformation
YARA	Pattern-based identification of files or artifacts
Volatility	Memory forensics
Sysmon	Detailed Windows system telemetry
osquery	Querying endpoint system information
VirusTotal	Multi-engine file and URL intelligence, subject to data-sharing considerations
Sigma	Portable descriptions of detection rules

Tools should be selected according to the investigation question. Uploading confidential files or indicators to external services requires authorization.

4. SOC Workflows and Scenarios

4.1 The Complete Toolkit Workflow

A standard investigation flow is:

Alert → Validation → Enrichment → Correlation → Investigation → Decision → Response → Documentation → Closure

At each stage, analysts should preserve timestamps, identify evidence sources, record decisions, and distinguish confirmed facts from assumptions.

4.2 Scenario: Suspicious Login

Situation: An employee account logs in from an unusual location after multiple failed authentication attempts.

Investigation:

1. Confirm the alert timestamp and affected account.
2. Review successful and failed authentication events.
3. Check source IP, device, MFA outcome, and session details.
4. Compare activity with the employee's normal pattern.
5. Look for password changes, new MFA methods, privilege changes, or suspicious application access.
6. Determine whether the event is legitimate, suspicious, or confirmed compromise.
7. Escalate and follow the approved response process.

Possible response actions include revoking sessions, resetting credentials, or temporarily restricting the account when justified and authorized.

4.3 Scenario: Ransomware

Situation: An endpoint produces a high volume of file modifications and an EDR ransomware alert.

Investigation and response:

1. Confirm the alert and identify the affected endpoint.
2. Review process trees, command lines, file activity, and related detections.
3. Determine whether other endpoints or shared resources are affected.
4. Follow the incident response plan to isolate affected systems.
5. Preserve evidence and relevant logs.
6. Escalate to incident responders.
7. Investigate the entry point and potential data exposure.
8. Support recovery using verified backups and approved procedures.
9. Document scope, actions, and lessons learned.

Do not immediately delete artifacts or rebuild a system before evidence-preservation requirements are considered.

4.4 Ethical Use of SOC Tools

SOC tools can expose sensitive information and allow powerful administrative actions.

Analysts must use them only within approved authorization, scope, and job responsibilities. They must protect personal data, avoid unnecessary collection, document sensitive actions, and never use privileged access for personal purposes.

4.5 Building a SOC Analyst Toolkit

A beginner toolkit may include:

- Log investigation: Splunk or Elastic Security.
- Endpoint investigation: An authorized EDR platform.
- Network analysis: Wireshark and Zeek.
- Windows investigation: Event Viewer and PowerShell.
- Linux investigation: journalctl, grep, and standard system utilities.
- Threat intelligence: Approved enrichment sources.
- Detection engineering: Sigma and YARA.
- Documentation: A ticketing system and investigation template.

Practice goal: Be able to explain what evidence each tool provides, what it cannot establish, and how the output supports an investigation.

==========

Module 4: SOC Logging and Analysis

1. Logging Fundamentals

1.1 Introduction to Logging

A log is a record of an event that occurred on a system, application, or network device.

A typical log contains a timestamp, source, event type, user or process, result, and additional context.

Example:

Timestamp: 2026-10-12 09:15:30
Host: WS-014
User: analyst1
Event: Authentication failure
Source IP: 192.0.2.25
Result: Failed

This is an illustrative record, not an actual event.

Why logs matter: They help analysts reconstruct activity, detect attacks, troubleshoot systems, investigate incidents, and demonstrate compliance.

1.2 Log Sources and Types

Source	Useful information
Windows endpoints	Logons, process activity, policy changes
Linux servers	Authentication, service activity, system events
Firewalls	Allowed and blocked connections
DNS servers	Domain queries and responses
Web proxies	URL access and web traffic
Applications	User actions, errors, access events
Cloud audit logs	API activity, configuration changes, identity actions
EDR platforms	Process trees, endpoint alerts, response actions
Email security	Phishing detections and message delivery events
Identity providers	Authentication, MFA, account and session events

1.3 Windows Event Logging

Windows records events in channels such as Security, System, Application, and PowerShell.

Security events may reveal logon activity, account creation, group membership changes, and privilege assignments.

Analysts should examine the event ID, timestamp, account, logon type, source address when available, and related events.

Example: Event ID 4625 represents a failed logon. Multiple failures followed by a successful logon may justify further investigation, but the pattern must be evaluated in context.

1.4 Linux Logging

Linux systems may record events in text files under /var/log/ or in a systemd journal.

Common sources include authentication logs, system logs, kernel messages, web server logs, and service-specific logs.

Useful commands:

journalctl
journalctl -u ssh
grep -i "failed" /var/log/auth.log

The example paths and service names vary by distribution. Use the relevant authentication log or journal for the system being investigated.

2. The Logging Lifecycle

2.1 Logging Lifecycle

A typical logging lifecycle includes:

1. Event generation.
2. Collection.
3. Transmission.
4. Parsing and normalization.
5. Enrichment and aggregation.
6. Storage and indexing.
7. Searching and analysis.
8. Retention, archival, and secure disposal.

Each stage must preserve data quality, security, and appropriate timestamps.

2.2 Log Collection

Log collection gathers event records from their original sources.

Methods include local agents, remote collectors, APIs, and native cloud integrations.

Common challenges: Missing permissions, disconnected agents, incompatible formats, network interruptions, and incomplete audit policies.

2.3 Log Shipping

Log shipping transfers logs from a source to a centralized destination.

Common approaches include agents, syslog, event forwarding, and cloud APIs.

Secure transport, buffering, retry handling, and monitoring of ingestion delays help prevent data loss.

2.4 Log Aggregation

Log aggregation combines records from multiple systems into a central platform.

Benefits include centralized searching, correlation, consistent retention, and investigation across different assets.

Example: A single incident may involve a firewall connection, a Windows authentication event, an EDR alert, and a cloud audit event. Aggregation allows analysts to correlate these sources.

2.5 Log Collection and Aggregation with Splunk

Splunk can ingest machine-generated data, parse events, index records, and support investigation using Search Processing Language (SPL).

Basic workflow:

1. Configure an authorized data source.
2. Send sample logs to Splunk.
3. Verify ingestion and timestamps.
4. Select the appropriate index and source type.
5. Search for relevant events.
6. Extract or filter important fields.
7. Build a simple report or dashboard.

Illustrative SPL searches:

```
index=* earliest=-24h
| stats count by host
index=* earliest=-24h
| search "failed"
| stats count by host, source
```

These broad searches are examples for a lab; actual index names and field mappings depend on configuration. Restrict searches to appropriate data sources in production.

3. Log Analysis

3.1 Basic Log Interpretation and Analysis

Analysts should understand:

- Timestamp: When the event occurred.
- Source: The system that generated the event.
- Actor: User, process, or service involved.
- Action: What happened.
- Target: Resource or system affected.
- Result: Success, failure, or error.
- Context: Related events and environmental details.

An effective investigation establishes a timeline and correlates events across multiple sources.

Example: A failed login followed by a successful login, a new privileged group membership, and an unusual data transfer may indicate a sequence requiring urgent investigation.

3.2 Log Analysis Tools

Tool	Use
Splunk	Search and correlate centralized logs
Elastic Stack	Ingest, search, and visualize data
Microsoft Sentinel	Cloud-based SIEM and security analytics
Windows Event Viewer	Inspect local and forwarded Windows events
journalctl	Query systemd journal logs
grep	Search text logs
jq	Process JSON-formatted records
Wireshark	Analyze packet captures

4. SIEM Fundamentals

4.1 Introduction to SIEM

SIEM stands for Security Information and Event Management.

It combines log collection, security analytics, correlation, alerting, and investigation capabilities.

Typical data flow:

Sources → Collection → Parsing → Indexing → Detection → Alerts → Investigation

A SIEM does not automatically guarantee threat detection. Coverage depends on log availability, correct parsing, detection quality, and analyst processes.

4.2 Dashboards and Visualizations

Dashboards summarize security activity using charts, tables, and metrics.

Useful SOC dashboards may show:

- Alerts by severity.
- Failed and successful authentication activity.
- Alerts by endpoint or user.

- Malware detections.
- Critical asset activity.
- Log ingestion health.
- Incident response times.
- Detection rule performance.

Dashboards help prioritize investigation but do not replace examination of the underlying evidence.

4.3 Effectively Using ELK

The ELK Stack traditionally refers to Elasticsearch, Logstash, and Kibana.

- Elasticsearch: Stores and searches indexed data.
- Logstash: Processes and transforms data.
- Kibana: Provides dashboards and data exploration.

Beats and Elastic Agent may also be used to collect and ship telemetry. Elastic Security provides security analytics capabilities within the broader Elastic platform.

Basic investigation: Filter by time range, host, user, source IP, and event type; compare related records; build a timeline; and save useful searches or visualizations.

4.4 Events, Alerts, and Incidents

Term	Meaning	Example
Event	A recorded occurrence	A user logs in
Alert	A notification that a detection condition was met	Many failed logins trigger a rule
Incident	A confirmed or formally managed security issue	An account is determined to be compromised

Not every event is an alert, and not every alert is a confirmed incident.

4.5 Alert Fatigue

Alert fatigue occurs when analysts face excessive alerts, particularly repetitive or low-value ones, making important alerts harder to identify.

Causes include noisy rules, duplicate alerts, poor thresholds, missing context, and unnecessary detections.

Ways to reduce alert fatigue:

- Tune thresholds using observed baseline activity.
- Suppress only understood and justified noise.
- Correlate related alerts.

- Enrich alerts with asset and identity context.
- Measure false positives and missed detections.
- Review rules regularly.
- Avoid suppressing genuinely risky activity just to reduce volume.

4.6 Logging and Analysis Challenges

Common challenges include:

- Missing or incomplete logs.
- Incorrect time zones and timestamps.
- Inconsistent field names and formats.
- Excessive event volume.
- Insufficient retention.
- Limited storage and licensing.
- Privacy and access restrictions.
- Poorly tuned detections.
- Unmonitored collection failures.
- Difficulty correlating events across systems.

Best practice: Monitor the logging pipeline itself. A sudden drop in authentication or endpoint logs may indicate an ingestion failure or a security-relevant change.

==========

Module 5: Incident Detection and Response

This module teaches students how to recognize suspicious activity, investigate security alerts, validate incidents, and follow a structured response process.

1. Incident Response Foundations

1.1 What Is Incident Response?

Incident response is the organized process of identifying, managing, containing, and recovering from cybersecurity incidents.

An incident may involve unauthorized access, malware infection, data theft, compromised accounts, service disruption, or policy violations.

Objectives of incident response:

- Reduce the impact of an attack.

- Identify affected systems and accounts.
- Preserve evidence.
- Stop ongoing malicious activity.
- Restore normal operations securely.
- Identify root causes and prevent recurrence.

Example: When ransomware is detected on an employee workstation, the organization investigates the affected endpoint, isolates it according to policy, determines whether other systems are affected, and coordinates recovery.

1.2 Incident Response Teams

Incident response often requires multiple teams working together.

Team	Responsibilities
SOC	Detects alerts, performs initial triage, and escalates
Incident Response Team	Coordinates investigation, containment, and remediation
Digital Forensics Team	Collects and examines digital evidence
IT Operations	Implements approved system changes and recovery
Network Team	Investigates network activity and applies network controls
Cloud Security Team	Investigates cloud identities, resources, and audit logs
Legal and Compliance	Advises on legal obligations and reporting
Management	Makes business decisions and allocates resources
Communications Team	Coordinates authorized internal and external communication

In smaller organizations, one person may perform several of these roles.

1.3 Incident Response Process

NIST's incident response guidance emphasizes preparation, detection and analysis, response activities, and improvement. NIST SP 800-61 Revision 3 aligns incident response with the broader CSF 2.0 risk management lifecycle.

- A practical incident workflow is:
- Preparation
- Policies, tools, access, playbooks, backups
- Detection and Analysis
- Validate alerts, investigate evidence, determine scope

- Containment
- Limit the incident's spread and impact
- Eradication and Recovery
- Remove the cause, restore systems, validate security
- Post-Incident Improvement
- Document lessons, improve controls, update detections
- The organization may need to revisit earlier stages as new evidence emerges.

1.4 Events, Alerts, and Incidents

These terms have different meanings.

- Event: Something happened in a system.
- Alert: A security tool identified a condition that may require attention.
- Incident: A security event or series of events requiring formal management under the organization's incident criteria.

Example:

A user logging in is an event. An alert for a login from an unusual location is a potential security warning. If investigation confirms that an unauthorized person accessed the account, the activity is managed as a security incident.

2. Detecting Incidents

2.1 Detecting Suspicious Activity

Suspicious activity is behavior that differs from expected or authorized activity and may indicate a threat.

Examples:

- Repeated failed authentication attempts.
- Logins outside expected patterns.
- Unexpected administrative privileges.
- Unusual PowerShell or shell commands.
- Security controls being disabled.
- Large or unexpected data transfers.
- Connections to suspicious external infrastructure.
- Unusual file modifications.
- Unexpected changes to cloud security settings.

Detection methods: SIEM correlation rules, EDR analytics, network monitoring, threat intelligence, anomaly detection, and threat hunting.

Important: Unusual activity is not automatically malicious. Analysts must investigate the context and supporting evidence.

2.2 Phishing and Email Compromise

Phishing is a deceptive communication designed to trick recipients into revealing information, opening malicious files, or visiting harmful websites.

Business Email Compromise (BEC) involves the abuse or impersonation of email accounts to manipulate business transactions or obtain sensitive information.

Warning signs include:

- Unexpected urgency or pressure.
- Lookalike domains.
- Unusual payment requests.
- Unexpected attachments.
- Suspicious links.
- Requests to bypass normal approval procedures.
- Unexpected authentication or mailbox-rule changes.

SOC investigation steps:

1. Obtain the reported email and preserve relevant headers.
2. Inspect sender and reply-to addresses.
3. Review email authentication results where available.
4. Extract URLs, domains, and file hashes.
5. Check email gateway and proxy logs.
6. Determine whether the email was delivered, opened, or interacted with.
7. Investigate related authentication and endpoint activity.
8. Follow the organization's process for message removal, account protection, and user notification.

Do not click suspicious links or open unknown attachments on a normal workstation during investigation.

2.3 Credential and Account Attacks

Credential attacks target passwords, authentication tokens, or other means of accessing accounts.

Common techniques include:

- Brute force: Repeatedly guessing passwords.
- Password spraying: Trying a small number of passwords across many accounts.
- Credential stuffing: Testing credentials stolen from other services.
- Phishing: Tricking users into revealing authentication information.
- Token theft: Obtaining session tokens or authentication tokens.
- Privilege abuse: Misusing an account's permissions.

SOC evidence sources: Authentication logs, identity provider logs, MFA events, endpoint telemetry, VPN logs, cloud audit logs, and account-change events.

Response options: Validate the activity, protect affected accounts, revoke sessions, reset credentials, investigate persistence or unauthorized changes, and escalate when compromise is suspected or confirmed.

2.4 Malware and Endpoint Compromise

Malware is software designed to perform unauthorized or harmful actions.

Types include ransomware, spyware, trojans, worms, remote-access malware, and credential stealers.

Possible indicators:

- Unexpected processes or executable files.
- Suspicious process relationships.
- Unusual persistence mechanisms.
- Unexpected outbound connections.
- Security tool tampering.
- Mass file modifications.
- Unusual scheduled tasks or service creation.

Investigation workflow:

1. Review the EDR alert and affected host.
2. Examine process trees and command lines.
3. Review file and registry activity.
4. Check network connections and DNS activity.
5. Identify related endpoints and accounts.
6. Preserve evidence.
7. Contain the endpoint when authorized and appropriate.
8. Escalate to the incident response team.

A file's name or hash alone may not provide enough information to determine whether it is malicious.

2.5 Network Intrusions

A network intrusion involves unauthorized access or activity against networked systems.

Examples include exploitation of exposed services, unauthorized remote access, lateral movement, command-and-control communication, and data exfiltration.

Evidence sources:

- Firewall logs.
- IDS/IPS alerts.

- Network flow records.
- DNS logs.
- Proxy logs.
- Packet captures.
- VPN and authentication logs.
- EDR telemetry.

Example: An endpoint connects to an unfamiliar external host over an unusual port. The analyst checks the destination, process responsible for the connection, DNS history, firewall logs, and endpoint alerts to determine whether the traffic is legitimate.

3. Incident Response Operations

3.1 Contextualizing and Validating Alerts

Alert contextualization adds relevant information, while validation determines whether the alert represents genuine suspicious activity.

Useful context includes:

- Asset criticality.
- User role and privileges.
- Source and destination IP addresses.
- Time of activity.
- Known maintenance or approved changes.
- Threat intelligence.
- Previous related alerts.
- Endpoint and identity telemetry.

Example: An alert for a new administrative login may be legitimate if it corresponds to an approved maintenance window. If the account has no administrative duties and the login is followed by suspicious activity, escalation may be necessary.

Analysts should document both supporting and contradicting evidence.

3.2 Alert Triage

Triage prioritizes alerts based on their potential risk and urgency.

A practical approach:

1. Read the alert and understand the detection logic.
2. Identify the affected user, host, and service.
3. Verify the time range and data quality.
4. Gather supporting logs and telemetry.

5. Determine whether the alert is a false positive, suspicious activity, or a confirmed incident.
6. Assess severity and business impact.
7. Escalate or close according to policy.
8. Record the rationale.

Severity should consider impact, likelihood, asset importance, privilege level, scope, and whether malicious activity is ongoing.

3.3 Incident Response Playbooks

An incident response playbook defines the steps to follow for a particular threat scenario.

A good playbook contains:

- Trigger conditions.
- Scope and assumptions.
- Required permissions.
- Data sources.
- Investigation steps.
- Decision points.
- Containment actions.
- Approval requirements.
- Escalation criteria.
- Communication procedures.
- Evidence-preservation requirements.
- Closure criteria.

Common playbooks include phishing, suspicious login, malware, ransomware, data exfiltration, and compromised cloud credentials.

3.4 Documentation and Reporting for Incident Response

Incident documentation should be factual, clear, chronological, and reproducible.

A useful incident record includes:

Field	Information to record
Incident ID	Unique reference number
Detection time	When the alert was generated
Incident time	When the suspicious activity occurred, if known
Affected assets	Systems, accounts, and services involved
Summary	Brief description of the issue

Evidence	Relevant logs, event IDs, hashes, and observations
Scope	Known affected resources
Actions taken	Investigation and containment steps
Current status	Open, investigating, contained, or resolved
Escalation	Team or individual notified
Recommendations	Follow-up actions

Distinguish the time an event occurred from the time it was detected or reported.

3.5 Tier 1 Incident Workflow

Tier 1 analysts typically perform the initial investigation and follow established escalation procedures.

Standard workflow:

1. Receive and acknowledge the alert.
2. Review the alert details and severity.
3. Identify the affected asset, user, and event.
4. Check relevant logs and basic threat intelligence.
5. Search for related events and duplicate alerts.
6. Determine whether the alert can be resolved within Tier 1 authority.
7. Escalate suspicious, high-impact, or complex activity.
8. Create or update the incident ticket.
9. Document the investigation and hand over relevant evidence.

Tier 1 analysts should not perform high-impact containment actions outside their authorization.

Module 5 – Practical Exercises

Exercise 1: Phishing investigation

Review a simulated email, inspect headers, extract indicators, identify affected users, and prepare an incident summary.

Exercise 2: Brute-force investigation

Analyze failed and successful login events, group them by account and source, and identify suspicious patterns.

Exercise 3: Endpoint malware investigation

Review a simulated EDR alert, examine the process tree and network activity, and recommend containment actions.

Exercise 4: Network intrusion investigation

Correlate firewall, DNS, and endpoint logs to determine whether an unusual connection requires escalation.

Exercise 5: Incident response tabletop

Assign roles to students and walk through detection, validation, containment, evidence handling, communication, and recovery.

Module 6: SOC Ticketing and Reporting

This module teaches students how to document investigations, communicate findings, track incidents, and hand over cases to other teams.

1. Ticketing Basics

1.1 Ticketing in the SOC

A SOC ticket is a structured record used to track an alert, investigation, incident, request, or remediation task.

Ticketing provides accountability and creates a record of what was investigated and what actions were taken.

Main purposes:

- Track security issues from detection to closure.
- Assign responsibilities.
- Record investigation evidence.
- Track severity and priority.
- Manage escalation and response deadlines.
- Support communication between teams.
- Provide audit and reporting records.

A ticket may represent an alert requiring investigation or a confirmed incident. These should not automatically be treated as the same thing.

1.2 Anatomy of a SOC Ticket

A well-structured ticket typically contains:

Field	Description

Ticket ID	Unique ticket identifier
Title	Concise description of the issue
Description	Summary of the detection or reported issue
Severity	Technical assessment of potential impact
Priority	Order and urgency of work
Status	Current workflow stage
Assignee	Person or team responsible
Reporter	Person or system that raised the ticket
Detection source	SIEM, EDR, user report, or another source
Affected asset	Host, account, application, or service
Evidence	Logs, timestamps, indicators, and observations
Timeline	Chronological investigation activity
Actions taken	Work performed and decisions made
Escalation details	Team or specialist involved
Resolution	Outcome and reason for closure

Example ticket title: High – Repeated Failed Logins Followed by Successful Authentication

A good title describes the observed behavior rather than asserting an unconfirmed compromise.

1.3 Common Ticketing Solutions

Platform	Typical use
ServiceNow	Enterprise incident and service management
Jira Service Management	Service requests, issue tracking, and workflows
TheHive	Security incident and case management
ManageEngine ServiceDesk Plus	IT service management
Microsoft Sentinel incident management	Managing SIEM-generated security incidents
Splunk Enterprise Security	Security alert investigation and incident workflow capabilities

Features vary by product, edition, and configuration.

2. Working with Tickets

2.1 SOC Ticket Lifecycle

A common ticket lifecycle is:

New — Ticket created

Assigned — Responsibility established

Investigating — Evidence collected and reviewed

Escalated / Pending — Specialist input or action required

Resolved — Required actions completed

Closed — Outcome documented and closure criteria met

Actual ticketing systems may have different statuses and allow cases to move between stages more than once.

2.2 Writing Quality Tickets

Good tickets should be:

- Clear: Use simple, unambiguous language.
- Concise: Include relevant facts without unnecessary text.
- Evidence-based: Separate observations from assumptions.
- Actionable: State what needs to happen next.
- Traceable: Include timestamps and evidence references.
- Professional: Avoid emotional or accusatory language.
- Complete: Include the relevant context, actions, and outcome.

Weak description:

“User login looks suspicious. Please check.”

Improved description:

“Multiple failed authentication attempts were recorded for account user01, followed by a successful login from a source address not previously observed in the available logs. The activity requires validation against approved access records and the user's normal login pattern. No compromise has been confirmed. Review the associated authentication events and MFA results, then escalate if the activity cannot be verified.”

This example is illustrative; actual tickets must use verified case evidence.

2.3 SOC Ticket Metadata

Metadata is structured information used to categorize, search, prioritize, and report tickets.

Common metadata fields include:

- Severity and priority.
- Category and subcategory.
- Detection source.
- Affected asset.
- Account or identity.
- Assigned team.
- Creation and update timestamps.
- Service-level agreement (SLA) deadline.
- Incident classification.
- Status and resolution code.
- Tags and related ticket IDs.

Why metadata matters: Correct categorization enables accurate reporting, workload analysis, trend detection, and efficient escalation.

3. Workflows and Documentation

3.1 SOC Ticket Escalation

Escalation transfers an issue to a higher support tier, specialist, or responsible team when additional expertise or authority is required.

Escalation may be required when:

- A potential incident has a high business impact.
- An account or system may be compromised.
- The investigation exceeds Tier 1 permissions.
- The scope is unclear or expanding.
- Evidence suggests ransomware or data exfiltration.
- Required response deadlines may be missed.
- Immediate action is needed from IT, identity, network, or cloud teams.

A good escalation includes:

1. Brief issue summary.
2. Reason for escalation.
3. Affected assets and users.
4. Relevant timestamps.
5. Evidence collected.

6. Actions already performed.
7. Current risk and uncertainty.
8. Recommended next steps.

Escalation should happen promptly when the organization's severity criteria require it, not only after every investigation step has been completed.

3.2 Collaborative Documentation

Multiple analysts may work on the same case. Documentation ensures continuity across shifts and teams.

Best practices:

- Record actions as they happen.
- Use a consistent timeline.
- Include search queries and evidence references.
- Record who performed important actions.
- Explain why decisions were made.
- Identify unresolved questions.
- Avoid duplicate or contradictory notes.
- Restrict sensitive case details to authorized people.

Example handover:

“Reviewed the authentication alert for account user01. Multiple failed logons were followed by one successful logon. MFA outcome and user confirmation remain pending. No confirmed compromise at this stage. Next action: validate the source and session with the identity team. Relevant event timestamps and search results are attached to the ticket.”

3.3 Writing an Incident Report

An incident report presents the investigation in a structured form for technical teams, management, or compliance stakeholders.

Recommended report structure:

1. Incident title and ID.
2. Executive summary.
3. Date and time of detection.
4. Incident timeline.
5. Affected systems, accounts, and services.
6. Detection method.
7. Technical findings and supporting evidence.
8. Scope and business impact.
9. Containment and remediation actions.
10. Root cause, if established.

11. Recovery status.
12. Remaining risks and limitations.
13. Lessons learned.
14. Recommendations and assigned follow-up actions.

Example executive summary:

“Security monitoring identified repeated failed authentication attempts followed by a successful login for an employee account. The SOC reviewed available authentication records and initiated validation with the identity team. The investigation remains open while the legitimacy of the session is assessed. No confirmed data exposure has been established from the evidence reviewed so far.”

A report must not claim that a system was compromised, data was stolen, or an incident was fully resolved unless the evidence supports that conclusion.

3.4 Soft Skills for SOC Analysts

Technical knowledge is essential, but effective SOC analysts also need strong communication and collaboration skills.

Important skills:

- Clear written communication.
- Concise verbal reporting.
- Analytical thinking.
- Attention to detail.
- Time management.
- Prioritization.
- Team collaboration.
- Professionalism under pressure.
- Confidentiality and ethical judgment.
- Willingness to learn from feedback.

Example: During a critical incident, an analyst should communicate what is known, what remains uncertain, what has already been done, and what action is needed next.

==========

Module 6: SOC Ticketing & Reporting

1. Ticketing Basics

1.1 Ticketing in the SOC

SOC ticketing is the process of recording, tracking, assigning, investigating, and resolving security alerts and incidents using a ticketing system.

A SOC receives alerts from security tools such as SIEM, EDR, firewalls, and IDS/IPS. Analysts use tickets to document each investigation, record evidence, assign responsibility, track progress, and communicate findings.

Objectives of SOC Ticketing

- Track security alerts and incidents.
- Assign tasks to responsible analysts.
- Record investigation findings and evidence.
- Monitor incident status and response deadlines.
- Support escalation and shift handovers.
- Maintain an audit trail of investigation activities.
- Ensure incidents are properly resolved and documented.

Example: A SIEM detects multiple failed login attempts followed by a successful login. The SOC analyst creates a ticket, investigates the authentication logs, records the findings, and escalates the case if unauthorized access is suspected.

SOC Ticket Workflow: Alert Detection, Ticket Creation, Assignment, Investigation, Escalation or Resolution, Documentation, Closure.

1.2 Anatomy of a SOC Ticket

A SOC ticket contains structured information required to investigate and manage a security issue.

Field	Description
Ticket ID	Unique identifier assigned to the ticket
Title	Short description of the issue
Description	Details about the alert or incident
Severity	Indicates the seriousness of the security issue
Priority	Indicates how urgently the ticket must be handled
Status	Current stage of the investigation
Assigned Analyst	Person responsible for the ticket
Detection Source	Tool that generated the alert
Affected Asset	System, account, or application involved

Timestamp	Date and time of the relevant activity
Evidence	Logs, alerts, indicators, and investigation results
Actions Taken	Steps already performed
Escalation Details	Team or specialist handling the case
Resolution	Final outcome and closure reason

Severity vs. Priority

Severity describes the seriousness and potential impact of a security issue, whereas priority determines how urgently the issue should be addressed based on risk, business needs, and response requirements.

1.3 Common Ticketing Solutions

ServiceNow: Enterprise platform used for incident management, task assignment, workflow automation, and SLA tracking.

Jira Service Management: Used to manage service requests, security-related issues, task assignments, and team collaboration.

TheHive: Security case-management platform used to organize investigations, evidence, observables, and response tasks.

Microsoft Sentinel: Cloud-based SIEM platform that supports security incident investigation, assignment, and response workflows.

Splunk Enterprise Security: Security analytics platform that supports alert investigation and security incident workflows.

ManageEngine ServiceDesk Plus: IT service-management platform used for ticket creation, assignment, tracking, and resolution.

2. Working with Tickets

2.1 SOC Ticket Lifecycle

The SOC ticket lifecycle describes the stages a ticket passes through from creation to closure.

Stage	Explanation
New	A new security issue or alert is recorded
Assigned	The ticket is assigned to an analyst or team
Investigating	The analyst collects and examines evidence

Escalated	The ticket is transferred to a higher-level analyst or specialist
Pending	The investigation is waiting for information or action
Resolved	The investigation or required remediation is complete
Closed	The ticket meets the organization's closure requirements

The exact status names depend on the ticketing platform and organizational procedures.

Example: A suspicious-login alert generates a ticket. A Tier 1 analyst reviews the logs, identifies unusual activity, and escalates the ticket to Tier 2. After investigation and appropriate response, the findings are documented and the ticket is closed.

2.2 Writing Quality Tickets

A quality SOC ticket communicates the security issue clearly and provides enough information for another analyst to continue the investigation.

Characteristics of a good ticket

- Clear and descriptive title.
- Accurate timestamps and affected assets.
- Relevant evidence and log references.
- Objective and professional language.
- Clear distinction between facts and assumptions.
- Description of actions already performed.
- Recommended next steps.
- Correct severity, priority, and status.

Example of a quality SOC ticket

Title: Repeated Failed Logins Followed by Successful Authentication

Description: Multiple failed authentication attempts were detected for an employee account, followed by a successful login from an unfamiliar source address.

Evidence: Authentication logs, timestamps, account details, source address, and SIEM alert information.

Actions Taken: Reviewed the available authentication events and searched for related security alerts.

Current Assessment: The activity is suspicious, but account compromise has not been confirmed.

Next Steps: Validate the login with the identity team, review MFA results and session activity, and escalate if unauthorized access is suspected.

Status: Investigating.

2.3 SOC Ticket Metadata

Ticket metadata is structured information used to categorize, prioritize, search, assign, and report security tickets.

Common metadata fields include:

Metadata	Purpose
Ticket ID	Uniquely identifies the ticket
Category	Classifies the issue, such as phishing or malware
Severity	Indicates the seriousness of the issue
Priority	Indicates the urgency of handling
Status	Tracks investigation progress
Assigned Team	Identifies the responsible team
Affected Asset	Identifies the affected system or account
Detection Source	Identifies the security tool that generated the alert
Created Time	Records when the ticket was created
Updated Time	Records the latest ticket update
SLA Deadline	Records the required response or resolution deadline
Tags	Helps categorize and search tickets
Resolution Code	Records the final outcome

Importance of ticket metadata: Accurate metadata supports incident tracking, reporting, workload management, trend analysis, and security audits.

3. Workflows and Documentation

3.1 SOC Ticket Escalation

Ticket escalation is the process of transferring a security issue to a higher-level analyst, specialist, or responsible team when additional expertise, authority, or urgency is required.

Reasons for escalation

- A possible security incident has high impact.
- An account or endpoint may be compromised.

- The investigation requires advanced technical skills.
- Ransomware or data exfiltration is suspected.
- A critical system is affected.
- The analyst lacks the authority to perform required actions.
- Response deadlines may be missed.

SOC escalation levels

Level	Responsibilities
Tier 1	Initial alert review, basic investigation, and triage
Tier 2	Detailed investigation, event correlation, and incident validation
Tier 3	Advanced threat analysis, threat hunting, and detection engineering
Incident Response Team	Incident containment, eradication, recovery, and coordination

Escalation process: Identify the reason for escalation, collect relevant evidence, document actions taken, summarize the risk, assign the ticket to the appropriate team, and record the next required actions.

Example: A Tier 1 analyst discovers that a suspicious login was followed by an unexpected privilege change. The analyst documents the relevant authentication and account-change events and escalates the ticket according to the organization's incident response procedure.

3.2 Collaborative Documentation

Collaborative documentation allows multiple SOC analysts and technical teams to share accurate investigation information.

It is particularly important when incidents continue across different shifts or require support from identity, network, endpoint, or cloud security teams.

Best practices

- Record investigation activities chronologically.
- Document relevant logs, timestamps, and evidence.
- Record actions taken and their results.
- Identify the analyst responsible for significant actions.
- Explain decisions and escalation reasons.
- Record unresolved questions and pending tasks.
- Avoid duplicate or contradictory information.
- Protect confidential information and restrict access appropriately.

Example of a shift handover note

Incident: Suspicious Login Activity

Investigation Completed: Initial alert review and authentication log analysis.

Findings: Multiple failed login attempts were followed by a successful login. The legitimacy of the session remains unverified.

Pending Actions: Validate the login with the identity team and review MFA and session activity.

Next Steps: Continue the investigation and escalate if evidence indicates unauthorized access.

Status: Open – Investigation in progress.

3.3 Writing an Incident Report

An incident report is a formal document describing a cybersecurity incident, the investigation performed, evidence collected, impact, response actions, and recommendations.

Objectives of an incident report

- Communicate incident details clearly.
- Maintain a formal record of the investigation.
- Identify affected systems and accounts.
- Document evidence and response actions.
- Explain confirmed impact and remaining uncertainty.
- Recommend improvements to prevent recurrence.
- Support management decisions, audits, and compliance requirements.

Structure of an incident report

Section	Content
Incident Title	Short description of the incident
Incident ID	Unique incident reference
Executive Summary	Brief overview of the issue
Detection Details	How and when the incident was detected
Incident Timeline	Chronological sequence of events
Affected Assets	Systems, users, accounts, and services involved
Investigation Findings	Evidence and analysis
Impact Assessment	Confirmed or potential consequences

Response Actions	Containment, remediation, and recovery
Root Cause	Established cause, if known
Current Status	Open, contained, recovering, or resolved
Recommendations	Actions to reduce future risk
Lessons Learned	Improvements identified after the incident

Example: Suspicious Authentication Incident Report

Incident Summary: Security monitoring detected multiple failed authentication attempts followed by a successful login for an employee account.

Detection Method: SIEM authentication alert.

Investigation Findings: The SOC reviewed the available authentication logs and identified activity requiring further validation.

Impact Assessment: The extent of any unauthorized access has not been established.

Actions Taken: Initial log analysis was completed, relevant evidence was documented, and the case was escalated for further investigation.

Current Status: Investigation in progress.

Recommendations: Validate the session, review MFA results, examine related account activity, and apply approved account-protection measures if compromise is confirmed.

Conclusion: The activity remains suspicious. Account compromise must not be reported as confirmed until sufficient evidence supports that conclusion.

3.4 Soft Skills for the SOC

Soft skills are communication, analytical, and interpersonal abilities that help SOC analysts work effectively with colleagues and other teams.

Skill	Importance
Communication	Clearly explain findings and security risks
Critical Thinking	Analyze evidence and evaluate alternative explanations
Attention to Detail	Identify relevant timestamps, indicators, and inconsistencies
Time Management	Prioritize alerts and meet response deadlines

Teamwork	Coordinate investigations with other security teams
Problem-Solving	Identify appropriate investigative and remediation steps
Professional Writing	Prepare clear tickets and incident reports
Decision-Making	Choose appropriate actions based on evidence and policy
Confidentiality	Protect sensitive information
Adaptability	Respond to changing threats and investigation requirements
Stress Management	Maintain accuracy during high-pressure incidents
Continuous Learning	Improve technical knowledge and investigative skills

Example: During a ransomware incident, an analyst should communicate the affected systems, available evidence, actions already taken, remaining risks, and assistance required without making unsupported claims.